GOAD Part 1: Scanning the Forest - Reconnaissance in an Active Directory Jungle

cyb3rbyte.medium.com/goad-part-1-scanning-the-forest-reconnaissance-in-an-active-directory-jungle-53a125bd2486

Cyb3rByte

May 8, 2025

Welcome to my very first writeup on Medium!
After months of diving deep into Penetration Testing and Active Directory exploitation, I've decided to start sharing what I've learned. And what better way to begin than with **GOAD-Light**, a purposely vulnerable Active Directory environment designed by [Orange Cyberdefense](#).

This series will walk through **realistic attack paths** used in red team operations, from recon to domain dominance. I hope this becomes a clear, hands-on reference for understanding how attackers move through an AD environment.

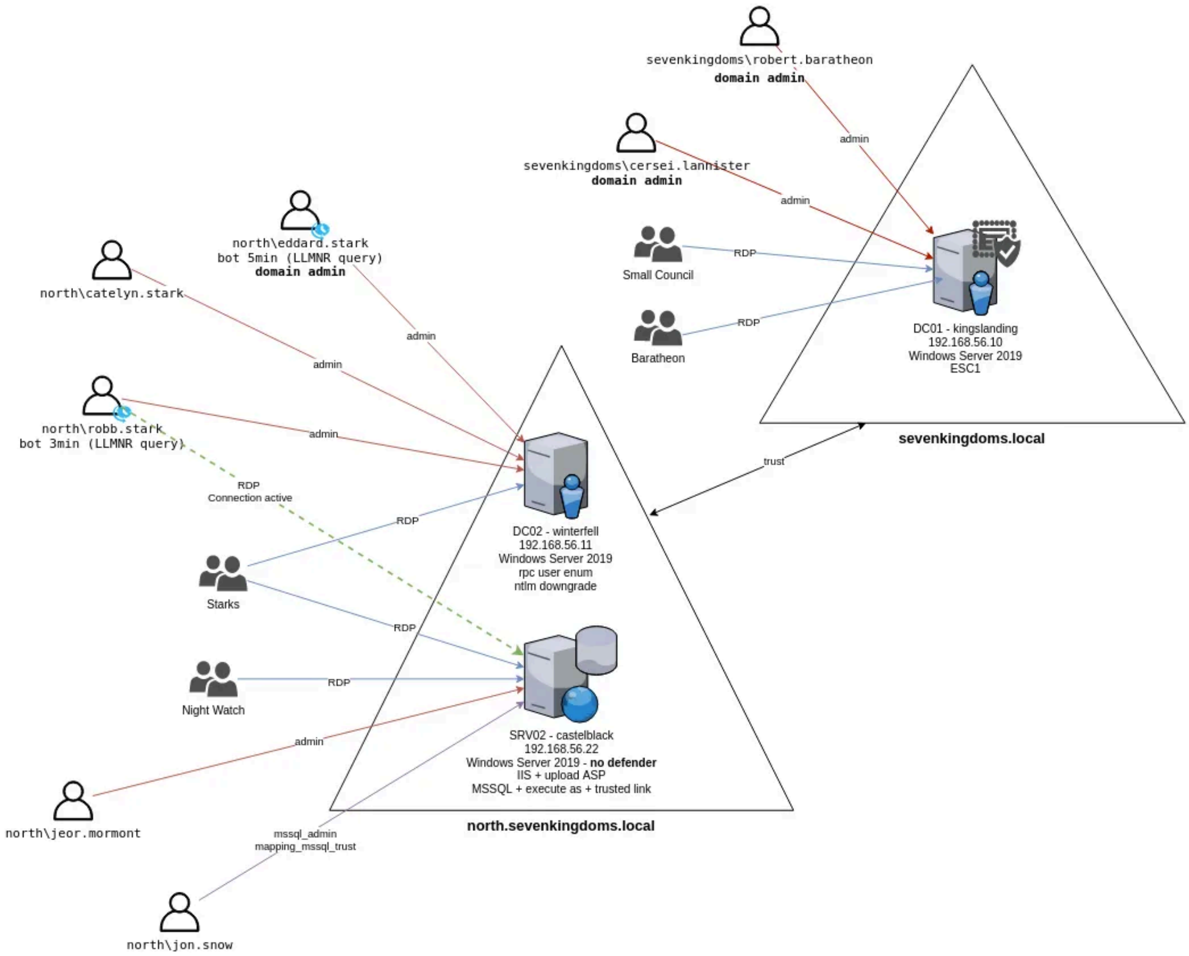
> 💡 ***Note**: I'll be skipping the **lab setup** part to keep things practical and focused on the attack flow. If you're interested in setting up GOAD in your own lab, I highly recommend checking out the official guide here:*
> [GOAD Setup Guide](#)

Let's get started with **Part 1** as every good breach begins with knowing your terrain!

1.0 Introduction

- This lab is consisted up of **3** machines, DC01, DC02, and SRV02.
- Purpose of Part 1: Reconnaissance and initial scanning
- Tools we will be using: `nmap`, `dig`, `netexec`.

Press enter or click to view image in full size



GOAD-Light Mapping

1.1 Network Discovery & Service Enumeration

First things first, we already know our scope will be **192.168.56.0/24**. So lets identify victim IPs:

Press enter or click to view image in full size

```
┌──(root㉿cyb3rbyte)-[/home/kali]
└─# nmap -sn 192.168.56.0/24 --exclude 192.168.56.1,192.168.56.100,192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-08 08:58 EDT
Nmap scan report for 192.168.56.10 (192.168.56.10)
Host is up (0.0011s latency).
MAC Address: 08:00:27:B9:AE:F3 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.11
Host is up (0.0054s latency).
MAC Address: 08:00:27:1C:8C:EA (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.22
Host is up (0.0018s latency).
MAC Address: 08:00:27:CB:D1:24 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 253 IP addresses (3 hosts up) scanned in 2.08 seconds
```

https://explainshell.com/explain?cmd=nmap+-sn+192.168.56.0%2F24+--exclude+192.168.56.1%2C192.168.56.100%2C192.168.56.101

Great now we are sure that there are only 3 targets: **192.168.56.10 — 192.168.56.11 — 192.168.56.22**

Using the following commands we can identify the most important ports to target them one at a time:

```
nmap -sP --open 192.168.56.10-22 -o initial.nmap
```

```
cat initial.nmap | grep "Nmap scan report" | cut -d " " -f6 | cut -d "(" -f2 | cut -d ")" -f1 > live.hosts
```

```
nmap -iL live.hosts -p 88,135,139,389,445,636,3268,3269,3389 -sV -O
```

Output:

```
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-08 10:32 EDT
Nmap scan report for sevenkingdoms.local (192.168.56.10)
Host is up (0.00098s latency).


PORT     STATE SERVICE       VERSION
88/tcp   open  kerberos-sec  Microsoft Windows Kerberos (server time: 2025-05-08 14:32:08Z)
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
389/tcp  open  ldap          Microsoft Windows Active Directory LDAP (Domain: sevenkingdoms.local0., Site: Default-First-Site-Name)
445/tcp  open  microsoft-ds?
636/tcp  open  ssl/ldap      Microsoft Windows Active Directory LDAP (Domain: sevenkingdoms.local0., Site: Default-First-Site-Name)
3268/tcp open  ldap          Microsoft Windows Active Directory LDAP (Domain: sevenkingdoms.local0., Site: Default-First-Site-Name)
3269/tcp open  ssl/ldap      Microsoft Windows Active Directory LDAP (Domain: sevenkingdoms.local0., Site: Default-First-Site-Name)
3389/tcp open  ms-wbt-server Microsoft Terminal Services
MAC Address: 08:00:27:B9:AE:F3 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Microsoft Windows 2019
OS CPE: cpe:/o:microsoft:windows_server_2019
OS details: Microsoft Windows Server 2019
Network Distance: 1 hop
Service Info: Host: KINGSLANDING; OS: Windows; CPE: cpe:/o:microsoft:windows


Nmap scan report for winterfell.north.sevenkingdoms.local (192.168.56.11)
Host is up (0.0010s latency).


PORT     STATE SERVICE       VERSION
88/tcp   open  kerberos-sec  Microsoft Windows Kerberos (server time: 2025-05-08 14:32:26Z)
```

```
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
389/tcp  open  ldap          Microsoft Windows Active Directory LDAP (Domain:
sevenkingdoms.local0., Site: Default-First-Site-Name)
445/tcp  open  microsoft-ds?
636/tcp  open  ssl/ldap      Microsoft Windows Active Directory LDAP (Domain:
sevenkingdoms.local0., Site: Default-First-Site-Name)
3268/tcp open  ldap          Microsoft Windows Active Directory LDAP (Domain:
sevenkingdoms.local0., Site: Default-First-Site-Name)
3269/tcp open  ssl/ldap      Microsoft Windows Active Directory LDAP (Domain:
sevenkingdoms.local0., Site: Default-First-Site-Name)
3389/tcp open  ms-wbt-server Microsoft Terminal Services
MAC Address: 08:00:27:1C:8C:EA (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open
and 1 closed port
Device type: general purpose
Running: Microsoft Windows 2019
OS CPE: cpe:/o:microsoft:windows_server_2019
OS details: Microsoft Windows Server 2019
Network Distance: 1 hop
Service Info: Host: WINTERFELL; OS: Windows; CPE: cpe:/o:microsoft:windows


Nmap scan report for castelblack.north.sevenkingdoms.local (192.168.56.22)
Host is up (0.00092s latency).


PORT     STATE  SERVICE           VERSION
88/tcp   closed kerberos-sec
135/tcp  open   msrpc             Microsoft Windows RPC
139/tcp  open   netbios-ssn       Microsoft Windows netbios-ssn
389/tcp  closed ldap
445/tcp  open   microsoft-ds?
636/tcp  closed ldapssl
3268/tcp closed globalcatLDAP
3269/tcp closed globalcatLDAPssl
3389/tcp open   ms-wbt-server     Microsoft Terminal Services
MAC Address: 08:00:27:CB:D1:24 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Microsoft Windows 2019
OS CPE: cpe:/o:microsoft:windows_server_2019
OS details: Microsoft Windows Server 2019
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows


Nmap scan report for 192.168.56.100
Host is up (0.00060s latency).


PORT     STATE    SERVICE           VERSION
88/tcp   filtered kerberos-sec
135/tcp  filtered msrpc
```

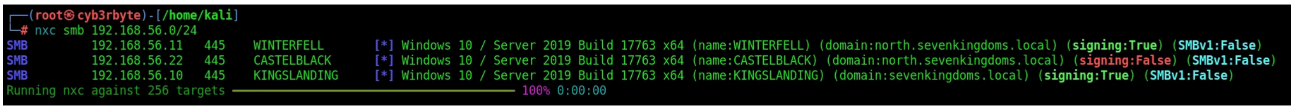
```
139/tcp  filtered netbios-ssn
389/tcp  filtered ldap
445/tcp  filtered microsoft-ds
636/tcp  filtered ldapssl
3268/tcp filtered globalcatLDAP
3269/tcp filtered globalcatLDAPssl
3389/tcp filtered ms-wbt-server
MAC Address: 08:00:27:F9:2A:D8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop


OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 4 IP addresses (4 hosts up) scanned in 49.40 seconds
```

1.2 Understanding the Environment

With deep scanning using **nmap** we can identify there Netbios names as well as there domains, another easy and quick method is with **netexec**:

Press enter or click to view image in full size



✦ **domain: sevenkingdoms.local**

kingslanding : DC01 running on Windows Server 2019

✦ **domain: north.sevenkingdoms.local**

- **winterfell**: DC02 running on Windows Server 2019
- **castelblack**: SRV02 running on Windows Server 2019 (**signing false**)

We have 2 domains so we know that there are **2 DCs** must be setup. With a close look we see **castelblack** has **signing off**. Microsoft by default setup **DC** smb signing as true.

Now we can add them in the`/etc/hosts` file:

Press enter or click to view image in full size

```
# GOAD
192.168.56.10   sevenkingdoms.local kingslanding.sevenkingdoms.local kingslanding
192.168.56.11   winterfell.north.sevenkingdoms.local  winterfell
192.168.56.22   castelblack.north.sevenkingdoms.local castelblack
```

> **Kerberos** is the **default authentication protocol** used by Active Directory. If we're interacting with AD systems from a Linux machine; especially for attacks or enumeration, we need a Kerberos client installed to request and handle Kerberos tickets.

Installation:

```
sudo apt install krb5-user
```

Now we will set up the **`/etc/krb5.conf`** file:

```
┌──(root㉿cyb3rbyte)-[/home/kali/GOAD]
└─# cat /etc/krb5.conf
[libdefaults]
    default_realm = SEVENKINGDOMS.LOCAL
    dns_lookup_realm = false
    dns_lookup_kdc = false

[realms]
    SEVENKINGDOMS.LOCAL = {
        kdc = 192.168.56.10
        admin_server = 192.168.56.10
    }

    NORTH.SEVENKINGDOMS.LOCAL = {
        kdc = 192.168.56.11
        admin_server = 192.168.56.11
    }

[domain_realm]
    .sevenkingdoms.local = SEVENKINGDOMS.LOCAL
    sevenkingdoms.local = SEVENKINGDOMS.LOCAL

    .north.sevenkingdoms.local = NORTH.SEVENKINGDOMS.LOCAL
    north.sevenkingdoms.local = NORTH.SEVENKINGDOMS.LOCAL
```

Read more

Now we are ready for the next step!

1.3 OSINT-like Domain Information Gathering

One of the most effective methods is querying **SRV DNS records**, which are used in **Active Directory** environments to locate essential services such as LDAP, Kerberos, and the Global Catalog.

Enumerating SRV Records via DNS

We used the `dig` command to query the internal DNS server (192.168.56.10) for various `_service._protocol.domain` SRV records. These queries help us discover the infrastructure and services without needing credentials or active scanning.

```
# 1. Query Global Catalog
dig @192.168.56.10 -t SRV _gc._tcp.sevenkingdoms.local
```

Output:
winterfell.north.sevenkingdoms.local. 3268
kingslanding.sevenkingdoms.local. 3268

> We identified two domain controllers acting as Global Catalog servers :`winterfell` (192.168.56.11) and `kingslanding` (192.168.56.10).

```
# 2. Query LDAP service
dig @192.168.56.10 -t SRV _ldap._tcp.sevenkingdoms.local
```

Output:
kingslanding.sevenkingdoms.local. 389

> This reveals that LDAP is available on kingslanding over the standard port 389.

```
# 3. Query Kerberos service
dig @192.168.56.10 -t SRV _kerberos._tcp.sevenkingdoms.local
```

Output:
kingslanding.sevenkingdoms.local. 88

> Kerberos authentication services are handled by the same host kingslanding, listening on the default port 88.

What's Next?

Now that we've identified DCs and there services, the next logical step in an Active Directory attack path is to **enumerate users and group memberships**, uncovering potential targets.

In **Part 2 :** ***"Hunting Domain Users Like an Attacker"*** .. we'll pivot from shares to identities, just like a real attacker would. **Stay tuned!** :)